TLP:CLEAR Unrestricted public release.

CYBER THREAT INTELLIGENCE REPORT

DigiCert discloses breach of archived customer data, including some identity documents

From **Cybersecurity Briefing** · 2026-11-05 to 2026-11-06 (US, Global, Industry); 2026-11-01 to 2026-11-06 (Indianapolis and Indiana) · Briefing generated 2026-11-06

REPORT ID	VERSION	HANDLING	BRIEFING SECTION
CTI-20261106-01	1.0 · 2026-11-06 08:02 EST	TLP:CLEAR	Industry
ORIGINAL PUBLISHED	**LAST UPDATE**	**CVES**	**ANALYST**
2026-11-05	No update	None	Nick Sturgeon

DATA BREACH | MEDIUM | CONTAINED; NOTIFICATIONS UNDERWAY | OVERALL CONFIDENCE: MODERATE

BOTTOM LINE UP FRONT

DigiCert, one of the largest public certificate authorities (CAs), has confirmed that an unauthorized party read archived customer records held in an internal business system. On 2025-02-04 an infrastructure migration moved the system from a VPN-restricted network segment into an internet-reachable availability zone. Nobody ran a security review of the change. The move also exposed a self-registration endpoint inherited from the underlying account-management platform, so outsiders could create accounts. Those self-registered accounts had no MFA and were not assigned to any application, but a flaw in the authorization model still let them read archived data. DigiCert's investigation found that one unauthorized account read records between 2026-06-27 and 2026-07-02. A patch on 2026-07-02 cut off that access [S1] [S2] [S3].

The exposed data is mostly business contact details: names, business email addresses, phone numbers and business addresses. A small minority of records also held identity documents that customers had submitted for validation, such as driver's licenses, passports or utility bills. DigiCert has not disclosed how many people or organizations are affected. It describes the exposure only as a small proportion of its archived data and has offered summary statistics privately to browser root programs [S1] [S2]. DigiCert says certificate issuance, CertCentral, DigiCert ONE, customer login credentials and issued certificates were not affected. It also says the access was read-only and could not approve

validations or issue, modify or revoke certificates [S1] [S2]. Customers do not need to reissue certificates [S5].

The bigger concern is how long detection took. DigiCert noticed outside accounts on 2026-06-18 and wrongly concluded they could not reach data. It received an outside researcher's report on 2026-06-21. It did not suspect data access until 2026-10-12 and confirmed it on 2026-10-19. Notification letters started going out around 2026-11-05 [S1] [S2]. This is DigiCert's second publicly reported security incident in 2026. In April, an attacker compromised its support portal, and 60 EV code-signing certificates were revoked after some were used to sign Zhong Stealer malware [S6]. No threat actor is named for the current incident, and no indicators of compromise have been published [S1] [S2] [S5].

What to do: find out which client organizations have DigiCert accounts and which staff submitted identity documents during organization or EV validation. Warn those people to expect a legitimate notice and phishing that uses DigiCert's name. Verify any unexpected certificate, payment or identity-document request through a known DigiCert portal or account manager. If DigiCert confirms that someone's identity document was exposed, involve privacy or legal staff and offer identity protection [S1] [S5].

Key judgments

LIKELY · MODERATE CONFIDENCE
Phishing and vishing that impersonate DigiCert or another CA and target certificate administrators are likely to increase over the next 30-60 days. Attackers will use the exposed business contact details and the publicity around the notices to push fake renewal, revalidation or 're-submit your ID' requests. [S1] [S5]

VERY UNLIKELY · MODERATE CONFIDENCE
The incident is very unlikely to have directly affected the trustworthiness of DigiCert-issued TLS or code-signing certificates. DigiCert's logs show no issuance, validation or revocation activity tied to the unauthorized account, and the access was read-only. [S1] [S2] [S3]

LIKELY · LOW CONFIDENCE
Browser root programs and the Mozilla community are likely to press DigiCert for more detail, such as affected record counts and why it suspected access on 2026-10-12. Together with the April 2026 support-portal incident, that pressure is likely to bring more public disclosures or audit-related commitments in the coming weeks. [S2] [S6]

UNLIKELY · LOW CONFIDENCE
Identity documents taken in this incident are unlikely to show up publicly in an attributable leak. Only a small minority of records held such documents and no extortion group has claimed the incident, but the actor's identity and intent are unknown. [S1] [S2]

INDICATORS OF COMPROMISE

Neither DigiCert's Bugzilla incident report nor any press coverage reviewed as of 2026-11-06 published technical indicators (IPs, account names, domains or hashes) [S2] [S5]. The single entry below is a derived hunting pattern for follow-on phishing, not an indicator of the intrusion itself.

Type	Indicator (defanged)	Context	Provenance	First seen	Source
other	`Inbound email naming DigiCert, certificate revalidation or identity-document re-submission, sent from a domain other than digicert.com`	Derived from the exposed data types (business contact details and validation documents) and the expected phishing risk. This is a lure pattern to hunt for, not a confirmed attacker artifact. Legitimate DigiCert mail can come from third-party senders, so check matches before blocking.	DERIVED		[S1] [S5]

Indicators are defanged (hxxp, [.], [@]) so they cannot be clicked. "Reported" means stated in a source; "Derived" means inferred by the analyst from the source material and should be validated before blocking.

TACTICS, TECHNIQUES & PROCEDURES (TTPS)

The intrusion did not need malware or credential theft. A misconfiguration did most of the work. A 2025 network migration put an internal business system and its self-registration endpoint on the internet. An outside party registered an account, which had no MFA requirement. The system's authorization logic assumed that only internal, application-assigned users could reach it, so it did not check whether an account had an assigned application. The self-registered account could therefore read archived customer representative records, including some uploaded identity documents, from 2026-06-27 to 2026-07-02. DigiCert's WAF block on the registration endpoint on 2026-06-18 did not stop access by an account that already existed. Access ended only when an authorization patch began returning HTTP 401 to accounts with no assigned application on 2026-07-02 [S2] [S3]. The main risk now falls on downstream targets: exposed contacts may receive social engineering, and exposed identity documents could be used for fraud.

MITRE ATT&CK mapping

Tactic	Technique	Procedure observed	Detection opportunity
Persistence	T1136 Create Account	An outside party used an internet-exposed self-registration endpoint to create accounts on DigiCert's internal business system. MFA did not apply to these accounts [S2] [S3]. [S2] [S3]	Alert on new accounts created through self-service registration on internal or partner-facing applications, especially accounts whose email domain is not one of your own.

Tactic	Technique	Procedure observed	Detection opportunity
Initial Access	T1190 Exploit Public-Facing Application	The self-registered account exploited a missing authorization check: accounts with no assigned application were not denied, so the internet-reachable system served archived data to them [S2]. [S2]	Review application logs for successful data requests by accounts that have no role or application assignment. Look for HTTP 200 responses where 401 or 403 would be expected.
Collection	T1213 Data from Information Repositories	Between 2026-06-27 and 2026-07-02 the unauthorized account read archived customer representative records and some uploaded identity documents [S1] [S2]. [S1] [S2]	Use application-level alerting on file access and request volume per account, the control DigiCert added on 2026-10-15 [S2].
Initial Access	T1566 Phishing	Anticipated follow-on activity, not observed: exposed business contact details could be used for DigiCert-themed phishing against certificate administrators [S1] [S5]. [S1] [S5]	Hunt for email that uses DigiCert or certificate-revalidation themes and comes from sender domains you do not expect.

Detection & hunting

Queries are built from the reported behavior and indicators. They are untested; tune field names for your environment.

DigiCert-themed email from non-DigiCert sender domains `KQL`

```
EmailEvents
| where Timestamp > ago(30d)
| where EmailDirection == "Inbound"
| where Subject has_any ("DigiCert", "certificate validation", "revalidation", "identity verification", "data breach notice")
| where SenderFromDomain !endswith "digicert.com"
| project Timestamp, SenderFromAddress, SenderFromDomain, RecipientEmailAddress, Subject, DeliveryAction, ThreatTypes
| order by Timestamp desc
```

Expect some benign hits from resellers, newsletters and security news. Add your known DigiCert partner or reseller domains to an allowlist. Join with EmailUrlInfo to review the linked domains.

Clicks on DigiCert lookalike domains `KQL`

```
UrlClickEvents
| where Timestamp > ago(30d)
| extend host = tostring(parse_url(Url).Host)
| where host has "digicert" or host matches regex @"d[i1l]g[i1l]cert"
| where not(host endswith "digicert.com")
| project Timestamp, AccountUpn, Url, host, ActionType, IsClickedThrough
```

Catches typosquats and DigiCert-branded subdomains on attacker infrastructure. Review hits by hand: DigiCert runs some services on other domains.

Self-registered accounts reading data on internal web apps (lesson-learned hunt) `SPLUNK SPL`

```
index=web sourcetype=access_combined (uri_path="*/register*" OR uri_path="*/signup*" OR uri_path="*/self-registration*") status=200
method=POST
| stats earliest(_time) as reg_time by src_ip, user
| join type=inner user [ search index=web sourcetype=access_combined status=200 method=GET | stats count as reads, dc(uri_path) as
distinct_paths, latest(_time) as last_read by user ]
| where reads > 50
| convert ctime(reg_time) ctime(last_read)
| sort - reads
```

This hunt is generic and does not target DigiCert. It looks for the same failure in your own environment: newly self-registered accounts that then pull large amounts of data. Change the index, sourcetype, field names and threshold to match your application logs.

REMEDIATION ACTIONS

Exposure

Product	Affected	Fixed in	CVE	CVSS	EPSS	CISA KEV	KEV due date

Product	Affected	Fixed in	CVE	CVSS	EPSS	CISA KEV	KEV due date
DigiCert internal business system (customer representative archive; not CertCentral or DigiCert ONE)	Archived customer contact records and some customer-submitted identity documents; data accessed 2026-06-27 to 2026-07-02	DigiCert-side fixes: authorization patch 2026-07-02; self-registration disabled and endpoints moved to private IPs 2026-10-24	None	N/A	N/A	No	N/A

Immediate (0–24 hours)

- Find out which organizations you support hold DigiCert accounts, directly or through resellers, and which staff acted as validation contacts or uploaded identity documents. `IT OPS` [S1] [S5]
- Warn certificate administrators and validation contacts that legitimate DigiCert notices are going out and that DigiCert-themed phishing is likely. Tell them to verify any request only through a known portal URL or account manager, not through links in the message. `SOC` [S1] [S5]
- Run the DigiCert-themed email and URL hunts. Add lookalike-domain detections to mail filtering. `SOC` [S1]

Short term (1–7 days)

- Through an authenticated channel, ask DigiCert to confirm whether your organization's records were accessed, which data categories were involved, and whether any identity documents were included. `LEADERSHIP` [S5]
- If identity documents are confirmed exposed, send the case to privacy or legal staff to assess notification duties under Indiana law. Offer the affected people credit monitoring and fraud alerts. `LEADERSHIP` [S1] [S5]
- Do not reissue certificates in bulk, migrate CAs in a hurry, or reset passwords across the board based on this incident alone. DigiCert reports that no certificates or customer credentials were affected. `IT OPS` [S1] [S5]

Long term

- Make security review mandatory in change management for any network or zone change that could expose an internal application. DigiCert's root cause was treating such a move as an infrastructure-only change. `LEADERSHIP` [S2]
- Audit your own internal and vendor applications for self-registration features and authorization that relies on network location rather than per-endpoint checks. `IT OPS` [S2] [S4]
- Include CA and other identity-proofing vendors in third-party risk reviews. Ask how long they keep identity documents and how they delete them, and give vendors only the identity documents they need. `LEADERSHIP` [S4] [S5]

- Since two DigiCert incidents have been disclosed in 2026, keep a tested plan for switching to a second CA for critical TLS and code signing in case trust or availability problems arise. `LEADERSHIP` [S6]

Workarounds & compensating controls

- Restrict who can request or approve certificates in CertCentral or DigiCert ONE, require MFA on those accounts, and use CAA DNS records so only approved CAs can issue for your domains. `IT OPS` [S1]
- Enable Certificate Transparency monitoring for your domains so you are alerted to any certificate issuance you did not expect. `SOC` [S2]

Actions marked with an owner: SOC = security operations, IT Ops = system and network administration, Leadership = risk and communications decisions.

SOURCES

[S1] BleepingComputer: DigiCert data breach exposes customer information, identity documents
Published 2026-11-05 · `B1` Usually reliable, confirmed by other sources
Briefing source. Confirms notification letters and DigiCert's scope statements; matches the Bugzilla report.

[S2] Mozilla Bugzilla (DigiCert incident report): Bug 2084460 - DigiCert: Unauthorized access to business system
Published 2026-10-20 · `A2` Completely reliable, probably true
Primary source. DigiCert's own public incident report, with timeline, root cause and action items. Community questions in the comments are still unanswered.

[S3] GBHackers: DigiCert Confirms Data Breach After Security Misconfiguration Exposes Customer Personal Information
Published 2026-11-05 · `C2` Fairly reliable, probably true
Secondary source that adds the MFA detail; one confirmation date is ambiguous on the year.

[S4] PrivacySavvy: DigiCert Confirms Unauthorized Access to Customer Identity Records After 17-Month Exposure
Published 2026-11-05 · `C2` Fairly reliable, probably true
Secondary summary of the Bugzilla report.

[S5] Rescana: DigiCert Archived Customer Data Access: Prepare Now Without Reissuing Certificates
Published 2026-11-06 · `C2` Fairly reliable, probably true
Vendor analysis with customer guidance; confirms that no IOCs were published.

[S6] SecurityWeek: DigiCert Revokes Certificates After Support Portal Hack
Published 2026-05-04 · `B1` Usually reliable, confirmed by other sources
Context on the separate April 2026 incident (Bugzilla 2033170).

Grades use the Admiralty scale: letter = source reliability (A completely reliable to F cannot be judged), number = information credibility (1 confirmed to 6 cannot be judged).

MISCELLANEOUS

Timeline

Date	Event	Source
2025-02-04	A migration moves the internal business system from a VPN-restricted segment to an internet-reachable zone, exposing its self-registration endpoint.	[S2]
2026-06-18	DigiCert notices non-DigiCert accounts, wrongly concludes they cannot reach data, and blocks the registration endpoint at the WAF.	[S2] [S3]
2026-06-21	DigiCert's managed security research program reports that outsiders may be able to create accounts.	[S2]
2026-06-24	External account creation confirmed.	[S2]
2026-06-27	An unauthorized account begins reading archived customer data.	[S1] [S2]
2026-07-02	An authorization patch returns 401 to accounts with no assigned application, ending the access.	[S2]

Date	Event	Source
2026-10-12	DigiCert first suspects unauthorized access to archived data.	[S2]
2026-10-19	Data access confirmed and classified as reportable.	[S1] [S2]
2026-10-20	DigiCert files a preliminary incident report on Mozilla Bugzilla.	[S2]
2026-10-24	Self-registration disabled; remaining endpoints moved to private IPs.	[S2]
2026-11-05	Customer notifications begin and public reporting follows.	[S1]
2026-11-06	Due date for DigiCert's remaining action item, an internal audit confirming no external origin servers.	[S2] [S5]

Relevance to Indianapolis, Indiana & managed clients

DigiCert certificates are widely used across Indiana: state and local government sites, hospital and health-system portals, universities and K-12 districts, manufacturers' code-signing and supplier portals, and small and mid-size businesses that buy through resellers or hosting providers. Organizations that went through organization (OV) or extended (EV) validation, or bought EV code-signing certificates, may have had an officer or IT administrator submit a driver's license or passport. Those people are the ones most exposed. Healthcare and government groups should expect certificate-themed social engineering aimed at their IT staff. If identity documents are confirmed exposed for Indiana residents, organizations should check with counsel about obligations under the state's breach notification law. For managed IT service clients, the main tasks are: list which clients use DigiCert, tell their certificate contacts what is happening, verify vendor requests through known channels, and avoid needless reissuance work. Certificate operations do not need to change, because DigiCert reports that no certificates or credentials were affected.

Intelligence gaps

- Number of affected individuals and organizations, and how many identity documents were viewed. DigiCert has shared these figures only with root programs.
- Who was behind the unauthorized account and why: researcher, opportunist or criminal actor.
- Whether the data was copied or exfiltrated, beyond being read.
- What prompted DigiCert to suspect data access on 2026-10-12. A community commenter has asked; no answer yet.

- Whether regulators or state attorneys general have been notified, and whether any notices went to Indiana residents.
- No IOCs (IPs, account identifiers) have been published; watch the Bugzilla thread for a final report and community follow-ups.
- Whether the earlier exposure window (from 2025-02-04 to 2026-06-18) included other unauthorized access that logs did not capture.

Other notes

- This is separate from DigiCert's April 2026 support-portal compromise (Bugzilla 2033170), in which malware delivered through customer chat led to 60 EV code-signing certificate revocations and Zhong Stealer signing [S6].
- In Bugzilla, Claves Nostrum asked DigiCert to state directly whether subscriber verification information was exposed and to give data-set counts. The reply that 'no certificates were affected' does not answer either question [S2].
- Sources describe the failed control differently. Some focus on the missing MFA for self-registered accounts [S3] [S4]; DigiCert's report treats the core flaw as an authorization model that ignored self-registered accounts [S2]. Both appear to be true.
- BleepingComputer cites a notice that cloud architect Fabian Bader posted publicly on X; the post could not be opened for this report [S1].

CTI-20261106-01 v1.0 · Generated 2026-11-06 08:02 EST from public reporting. Drafted with AI assistance and reviewed by Nick Sturgeon. Verify indicators and actions before operational use. Summaries are in the analyst's own words.

Back to the daily briefing.

TLP:CLEAR Unrestricted public release.